

pankinasw Create technical-specification.md

5d56ef3 · 2 days ago

162 lines (139 loc) · 18.8 KB

PreviewCodeBlame

Raw

Техническое задание

на разработку системы «СУПД — Система управления правами доступа и учётными записями» (Identity Governance & Administration, IGA/IDM)

Версия 1.1 от 05 декабря 2025 г.

1. Общие положения

Параметр	Значение
Полное наименование	Система управления правами доступа и учётными записями пользователей в корпоративных информационных системах
Краткое наименование / код	СУПД
Регистрационный номер в ИТ-учёте	000.205.000.000
Заказчик	Департамент информационной безопасности
Количество пользователей	> 1 000 активных сотрудников + подрядчики (ожидаемый рост до 1 500 в течение года)
Количество управляемых ИС	27 (глобальные и локальные РФ, с возможностью расширения до 35)

Параметр	Значение
Срок реализации	6 месяцев с момента утверждения ТЗ (с возможностью корректировки на основе этапа анализа)
Бюджет на лицензии	0 Р (только open-source компоненты, без проприетарного ПО)

Примечание: В случае необходимости использования дополнительных open-source инструментов, они должны быть предварительно согласованы с Заказчиком.

2. Цели и задачи проекта

№	Цель / задача	Целевой показатель	Метрика измерения
1	Обеспечить новых сотрудников базовым набором доступов в течение 1 рабочего дня	≤ 24 ч	Время от приема на работу до активации birthright-ролей
2	Обеспечить действующих сотрудников дополнительными доступами	≤ 48 ч	Время от подачи заявки до исполнения
3	Исключить несанкционированное и некорректное предоставление прав	100 % автоматическая проверка SoD	Количество заблокированных заявок с конфликтами
4	Полностью уйти от бумажного документооборота по заявкам на доступ	100 % электронный юридически значимый документооборот	Доля заявок, обработанных электронно
5	Создать единый актуальный справочник сотрудников, ролей и	Один источник правды	Синхронизация данных без расхождений > 1 %

№	Цель / задача	Целевой показатель	Метрика измерения
	ресурсов		
6	Обеспечить ежеквартальную ресертификацию доступов и автоматический отзыв просроченных	100 % охват	Доля ресертифицированных доступов в кампании

Дополнительные задачи:

- Минимизировать ручной труд администраторов (цель: автоматизация ≥ 80 % операций).
- Обеспечить интеграцию с существующими системами без нарушения их работы.

3. Область применения и масштабы

- **Пользователи:** 1 000+ активных сотрудников, включая подрядчиков и временных работников.
- **Организационная структура:** 16 департаментов, 11 локаций (Москва, Самара, Краснодар, Новороссийск и др.), с поддержкой иерархии.
- **Роли:** 83 бизнес-роли (с возможностью добавления новых без перезапуска системы).
- **Целевые системы:** 27 информационных систем, включая SAP S/4HANA, 1C:ERP, Microsoft 365, ServiceNow, ФГИС Зерно и др. (приоритет на ключевые: 5 систем в первой фазе).
- **Ограничения:** Система не предназначена для управления физическим доступом (например, пропусками в здания). Фокус на цифровых аккаунтах и правах.

4. Функциональные требования (по подсистемам)

4.1. Self-service портал и интерфейсы

Требование	Обязательно	Детали
Три типа интерфейса: Открытый (для гостей), Защищённый (с	Да	Поддержка двухфакторной

Требование	Обязательно	Детали
ПКЗИ для чувствительных данных), Мобильный (только согласование)		аутентификации (MFA) для защищённого.
Адаптивный дизайн (desktop + mobile PWA)	Да	Progressive Web App для офлайн-доступа к базовым функциям.
Поддержка браузеров: Safari iOS, Firefox Android, Chrome, Edge	Да	Тестирование на актуальных версиях (не старше 1 года).
Первичное подтверждение ознакомления с ЛНД (локальными нормативными документами)	Да	Электронная подпись или чекбокс с логгированием.

4.2. Управление пользователями и оргструктурой

Функция	Обязательно	Детали
Импорт и ежедневная синхронизация из 1С:ЗУП (CSV / REST)	Да	Автоматический импорт по расписанию (cron), обработка дельты изменений.
Полная карточка сотрудника (трудоустройства, доступы, история)	Да	Поиск по ФИО, табельному номеру; экспорт в PDF/CSV.
Поддержка иерархической оргструктуры (Управление → Отдел → Подразделение → Локация)	Да	Визуализация в виде дерева; поддержка перемещений с автоматическим обновлением ролей.
Автоматическое назначение birthright-ролей при приёме/перемещении	Да	На основе должности и локации.
Автоматический отзыв всех доступов при увольнении	Да	С уведомлением администратора и логгированием.

4.3. Управление ролями и матрица доступа (RBAC + SoD)

Функция	Обязательно	Детали
Поддержка 83 ролей и матрицы доступа к 27 ИС (уровни: Admin / Read-Write / Read / No)	Да	Матрица в формате редактируемой таблицы (UI).
Автоматическая проверка SoD при подаче заявки (реестр ≥ 10 конфликтов)	Да	Блокировка заявки с объяснением конфликта; возможность исключений с одобрением ИБ.
Возможность создания составных ролей и связанных полномочий	Да	Иерархия ролей (родительские/дочерние).
Назначение ролей на должность / подразделение (birthright)	Да	Массовое назначение для групп.

4.4. Управление заявками и workflow

Этап workflow	Обязательно	Детали
Подача заявки (для себя / за другого)	Да	Шаблоны заявок; валидация полей.
Автоматическая проверка SoD	Да	Интеграция с матрицей ролей.
Последовательное согласование: 1. Линейный руководитель 2. ИБ компании 3. ИБ материнской компании 4. Владелец ИС/роли	Да	Параллельное согласование для ускорения, если возможно.
Таймауты (3 рабочих дня на этап) + эскалация	Да	Автоматическая эскалация к вышестоящему; уведомления по email/SMS.
Автоматическое/ручное исполнение после	Да	Провизининг в целевые ИС.

Этап workflow	Обязательно	Детали
финального одобрения		
Отмена заявки, история всех этапов	Да	Аудит-лог с timestamps.

4.5. Ресертификация доступов

Функция	Обязательно	Детали
Ежеквартальные кампании ресертификации	Да	Автоматический запуск по расписанию.
Автоматическое уведомление руководителей	Да	Через портал/email; напоминания за 7/3/1 день.
Срок подтверждения — 14 дней → автоматический отзыв	Да	Отчет о просроченных с причинами.

4.6. Интеграции и провизининг

Целевая система	Тип интеграции	Обязательно	Детали
1C:ЗУП	CSV / REST (HR-feed)	Да	Ежедневная синхронизация.
Active Directory / Entra ID	LDAP / SCIM	Да	Автоматический provisioning.
SAP S/4HANA, SAP Ariba и др.	SCIM / REST	Да	Поддержка OAuth2.
Microsoft 365	SCIM / Graph API	Да	Управление группами.
1C:ERP, 1C:TMS и др.	REST / LDAP	Да	Кастомные коннекторы.
ФГИС Зерно, Меркурий, Честный ЗНАК	REST (при наличии)	Желательно	Если API доступно; иначе ручной режим.

4.7. Аудит, отчётность и compliance

Тип отчёта	Периодичность	Обязательно	Детали
Отчёт для внутренних/ внешних аудиторов	ежеквартально	Да	Экспорт в PDF/ Excel.
Executive summary для руководства	ежеквартально	Да	Ключевые метрики (SLA, конфликты).
Compliance-отчёт для регуляторов (GDPR, SOX, 152-ФЗ)	по запросу	Да	Соответствие стандартам.
Реестр SoD-конфликтов и исключений	в реальном времени	Да	Дашборд в UI.

5. Нефункциональные требования

Категория	Требование	Метрика
Доступность	99,95 % (SLA)	Мониторинг uptime.
Время отклика UI/ API	≤ 2 сек (95-й процентиль)	Тестирование под нагрузкой.
Нагрузка	1 000 одновременных пользователей	Масштабируемость (horizontal scaling).
Хранение логов аудита	не менее 365 дней	Архивация старых логов.
Резервное копирование	ежедневно, RPO ≤ 4 ч, RTO ≤ 8 ч	Тестирование восстановления.
Безопасность	TLS 1.3, шифрование в покое, MFA для привилегированных ролей, аудит всех действий	Compliance с OWASP Top 10.
Соответствие стандартам	ISO 27001, SOX 404, GDPR, ФЗ-152, ФЗ-63, требования ФСТЭК	Сертификация по завершении.

Категория	Требование	Метрика
Масштабируемость	Поддержка роста пользователей на 50 % без перестройки	Kubernetes-ready.

6. Технологический стек (обязательный — только open-source)

Слой	Технология	Версия (рекомендуемая)	Обоснование
IGA-движок	Evolveum midPoint	4.8+	Стандарт для IGA.
SSO / Self-service	Authentik	2025.x	Легковесный, open-source.
Workflow	Temporal.io	1.25+	Надежный оркестратор.
Frontend	React 18 + TypeScript + Material-UI	—	Современный UI.
Backend / интеграции	Go 1.23 или Python 3.12 + FastAPI	—	Высокая производительность.
БД	PostgreSQL	16	Надежное хранение.
Хранилище объектов	MinIO	—	S3-совместимое.
Контейнеризация	Docker + Docker Compose / Kubernetes (k3s)	—	Для dev/prod.
CI/CD	GitHub Actions / GitLab CI	—	Автоматизация.

Слой	Технология	Версия (рекомендуемая)	Обоснование
Инфраструктура как код	Terraform + Helm	—	IaC для reproducibility.

Примечание: Все компоненты должны быть контейнеризированы для легкого развертывания. Запрет на проприетарные зависимости.

7. Этапы и сроки реализации

Этап	Срок	Результат	Зависимости
1. Анализ и архитектура	4 недели	TЗ утверждено, High-Level Design, Threat Model, Risk Assessment	Утверждение TЗ.
2. Разработка ядра (midPoint + Authentik + Temporal)	10 недель	Рабочий прототип с workflow и SoD	Доступ к тестовым данным.
3. Интеграции (1С ЗУП + 5 ключевых ИС)	6 недель	Автоматический joiner/leaver + провизининг	API-документация от ИС.
4. UI/UX + мобильная версия	4 недели	Полностью готовый портал с тестированием usability	Прототип ядра.
5. Ресертификация + отчётность	3 недели	Кампании + 3 вида отчётов	Интеграции.
6. Тестирование и приёмка	4 недели	UAT, нагрузочное, penetration testing (OWASP ZAP + ручное)	Полная система.
7. Документация и передача	2 недели	Руководства пользователя и администратора, видео, исходный код в Git	Завершение тестирования.

Итого: 26 недель (≈ 6 месяцев). Риски задержек: интеграции с legacy-системами (mitigation: пилот на 2 ИС).

8. Критерии приёмки проекта

1. Система запускается командой `docker compose up -d` на чистой машине за ≤ 15 минут (тест на Ubuntu 22.04+).
2. Полностью реализован workflow с 5 согласующими и автоматической проверкой SoD (тест на 10 сценариях).
3. Импортированы 500 тестовых пользователей из предоставленного Excel (без ошибок $> 1\%$).
4. Работает ежеквартальная ресертификация (симуляция кампании с 100 пользователями).
5. Сгенерированы и утверждены все три вида отчётов (проверка на compliance).
6. Прошёл penetration test (OWASP ZAP + manual) без критических уязвимостей (CVSS ≥ 7.0).
7. Передана вся документация (в Markdown/PDF), исходный код в GitHub (с CI/CD пайплайнами), и проведено обучение (2 сессии по 4 ч).

Дополнительные критерии: SLA на этапе UAT $\geq 99\%$; покрытие кода тестами $\geq 80\%$.

Утверждаю:

Директор по информационной безопасности

_____ / ФИО /

«__» _____ 2025 г.

Изменения в версии 1.1: Улучшена структура (добавлены детали, метрики, примечания); исправлено форматирование; добавлены разделы по рискам и зависимостям; уточнены требования для большей измеримости и полноты.

→ [Download as PDF](#)